Penetration Testing Report

ACME Corporation

Prepared by: Sentrix Security Ltd.

Report Reference: SENT-2026-ACME-0914
Classification: CONFIDENTIAL
Date: 14 September 2026
Version: 1.0 (Final)

1. Executive Summary

Sentrix Security Ltd. was engaged by ACME Corporation to conduct an external and internal penetration test of their production infrastructure. The assessment was performed between 5 September 2026 and 13 September 2026.

A total of 10 vulnerabilities were identified across the assessed infrastructure. Of these, 4 are rated Critical, 3 are rated High, and 3 are rated Medium. The most severe findings involve remote code execution on the public-facing web server, SQL injection in the customer portal, default credentials on a development database, and missing multi-factor authentication on the administrative VPN.

We recommend immediate remediation of all Critical findings within 72 hours. High severity findings should be addressed within 7 days. A full remediation plan with prioritized actions is included in this report.

2. Vulnerability Summary

ID	Title	Severity	CVSS	Affected Asset
F-001	Remote Code Execution via Path Traversal in nginx Upload Mod	Critical	9.8	web-prod-01.web.acme.local
F-002	SQL Injection in Customer Portal Login Endpoint	Critical	9.1	customer-portal.app.acme.local
F-003	Outdated TLS Configuration on Payment Gateway	High	7.5	payments.acme.local
F-004	Missing Multi-Factor Authentication on Admin VPN	Critical	9.0	vpn.acme.local
F-005	Default Credentials on Development MongoDB Instance	Critical	9.8	dev-db-03.db.acme.local
F-006	Public Read Access on S3 Bucket Containing PII Logs	High	7.2	acme-logs (S3)
F-007	Vulnerable OpenSSL Version on Mail Server (Heartbleed)	Medium	5.0	mail01.mail.acme.local
F-008	Stored Cross-Site Scripting on Marketing Blog	Medium	6.1	out.marketing.acme.local
F-009	Excessive Admin Permissions on GitHub Organization	Medium	5.4	github.com/acme
F-010	Unencrypted Backup Tapes in Transit	High	7.0	backup-tape-lot-0917

3. Detailed Findings

Each finding below includes a description, impact assessment, and recommended remediation steps.

F-001: Remote Code Execution via Path Traversal in nginx Upload Module

Severity:	Critical	**CVSS:**	9.8
Affected Asset:	web-prod-01.web.acme.local	**Asset Type:**	Web Server
Exposure:	Internet-facing	**CVE:**	N/A

Description:

The legacy upload module on the public-facing nginx server allows path traversal via specially crafted multipart form data. An unauthenticated attacker can traverse directory structures and upload a web shell to the webroot, achieving remote code execution as the nginx worker user. A public exploit for this configuration is available.

Impact:

Full system compromise of the primary web server. Attacker can read/modify all web content, pivot to internal network, and potentially access the backend database containing customer PII.

Recommendation:

1. Immediately disable the legacy upload module in nginx.conf.
2. Upgrade nginx to version 1.27.x which removes the vulnerable code path.
3. Implement a WAF rule to block path traversal patterns in multipart form data.
4. Rotate all SSL certificates and API keys stored on the server.
5. Conduct a forensic review of access logs for indicators of compromise.

F-002: SQL Injection in Customer Portal Login Endpoint

Severity:	Critical	**CVSS:**	9.1
Affected Asset:	customer-portal.app.acme.local	**Asset Type:**	Web Application
Exposure:	Internet-facing	**CVE:**	CVE-2024-3120

Description:

The login.do endpoint accepts a user parameter that is concatenated directly into a SQL query without parameterization. Boolean-based blind SQL injection was confirmed by extracting the database version string through time-delay techniques. The backend database is MySQL 8.0.

Impact:

Attacker can dump the entire customer database including credentials (stored as MD5 hashes), personal information, and order history. This constitutes a PII breach under GDPR.

Recommendation:

1. Replace all dynamic SQL with parameterized prepared statements.
2. Rotate all database credentials immediately.
3. Implement input validation using an allowlist approach.
4. Deploy a WAF with SQL injection detection rules.
5. Force password reset for all users due to potential credential exposure.

F-003: Outdated TLS Configuration on Payment Gateway

Severity:	High	**CVSS:**	7.5
Affected Asset:	payments.acme.local	**Asset Type:**	Application
Exposure:	Internet-facing	**CVE:**	N/A

Description:

The payment gateway accepts TLS 1.0 and TLS 1.1 connections. These protocols have known cryptographic weaknesses and are prohibited under PCI DSS 3.2.1 Requirement 4.1. The server also accepts weak cipher suites including RC4 and 3DES.

Impact:

PCI DSS non-compliance. Risk of decryption attacks on payment traffic. Potential fines from acquiring bank and card brands.

Recommendation:

1. Update nginx configuration to enforce TLS 1.2 minimum (preferably 1.3).
2. Remove weak cipher suites (RC4, 3DES, CBC mode ciphers).
3. Enable HSTS with a minimum age of 6 months.
4. Request a PCI ASV re-scan to verify compliance.
5. Update the security configuration baseline document.

F-004: Missing Multi-Factor Authentication on Admin VPN

Severity:	Critical	**CVSS:**	9.0
Affected Asset:	vpn.acme.local	**Asset Type:**	Network
Exposure:	Internet-facing	**CVE:**	N/A

Description:

The SSL VPN admin console permits remote login using only username and password credentials. No multi-factor authentication is enforced for administrator accounts. Password policy allows 8-character passwords with minimal complexity. The VPN provides full internal network access upon authentication.

Impact:

A compromised admin credential (via phishing, brute force, or credential stuffing) grants full access to the internal network, bypassing all perimeter controls.

Recommendation:

1. Enable MFA (TOTP or push notification) for all admin VPN accounts immediately.
2. Extend MFA requirement to all VPN users within 30 days.
3. Increase minimum password length to 14 characters.
4. Implement account lockout after 5 failed attempts.
5. Enable VPN session recording for admin accounts.

F-005: Default Credentials on Development MongoDB Instance

Severity:	Critical	**CVSS:**	9.8
Affected Asset:	dev-db-03.db.acme.local	**Asset Type:**	Database
Exposure:	Internal	**CVE:**	N/A

Description:

The MongoDB instance on dev-db-03 is accessible on port 27017 without authentication. The default admin/admin credentials are active. The database contains a mirror of production data including customer records used for testing. The host is reachable from the internal network without network segmentation.

Impact:

Any user on the internal network can access full production-equivalent data. If the internal network is compromised via VPN or other means, this becomes a trivial data exfiltration point.

Recommendation:

1. Enable MongoDB authentication immediately.
2. Rotate all credentials.
3. Bind MongoDB to localhost only (or specific internal subnet).
4. Implement network segmentation between development and production networks.
5. Scrub all PII from development databases; use synthetic data instead.

F-006: Public Read Access on S3 Bucket Containing PII Logs

Severity:	High	**CVSS:**	7.2
Affected Asset:	acme-logs (S3)	**Asset Type:**	Cloud Storage
Exposure:	Internet-facing	**CVE:**	N/A

Description:

The S3 bucket "acme-logs" has a bucket policy granting read access to all principals (*). The bucket contains application logs that include customer email addresses, IP addresses, and session tokens. The bucket is listed in the public AWS S3 directory.

Impact:

Anyone on the internet can download all logs containing PII. Session tokens in logs could enable session hijacking. GDPR breach notification may be required.

Recommendation:

1. Remove the public read policy immediately.
2. Apply a restrictive bucket policy allowing only the log-writer IAM role.
3. Enable S3 Block Public Access at the account level.
4. Enable server-side encryption (SSE-KMS).
5. Review all other S3 buckets for similar misconfigurations.
6. Scrub session tokens from future log entries.

F-007: Vulnerable OpenSSL Version on Mail Server (Heartbleed)

Severity:	Medium	**CVSS:**	5.0
Affected Asset:	mail01.mail.acme.local	**Asset Type:**	Mail Server
Exposure:	Internal	**CVE:**	CVE-2014-0160

Description:

The mail server is running a pinned Docker image with OpenSSL 1.0.1f, which is vulnerable to CVE-2014-0160 (Heartbleed). This allows an attacker to read up to 64KB of server memory per request, potentially exposing private keys and session tokens.

Impact:

Exposure of TLS private keys would allow decryption of all mail traffic. Session tokens could enable account takeover.

Recommendation:

1. Rebuild the Docker image with OpenSSL 1.1.1 or later.
2. Rotate the TLS certificate and private key.
3. Rotate all mail user session tokens.
4. Update the CI/CD pipeline to scan images for known vulnerabilities.
5. Set up automated dependency scanning.

F-008: Stored Cross-Site Scripting on Marketing Blog

Severity:	Medium	**CVSS:**	6.1
Affected Asset:	out.marketing.acme.local	**Asset Type:**	Website
Exposure:	Internet-facing	**CVE:**	CVE-2023-44487

Description:

The blog comment field on the marketing site does not sanitize user input before storing and rendering it. A stored XSS payload was confirmed by injecting a script tag that executes when any user views the comment. The site shares a CDN domain with the main application, creating a potential for cookie theft.

Impact:

Attacker can steal session cookies of visitors, deface the site, or redirect users to phishing pages. Reputational damage if exploited publicly.

Recommendation:

1. Sanitize all user input using an HTML allowlist library.
2. Set Content-Security-Policy headers (script-src self only).
3. Set HttpOnly and Secure flags on all cookies.
4. Implement output encoding for all dynamic content.
5. Consider moving the blog to a separate domain to isolate cookies.

F-009: Excessive Admin Permissions on GitHub Organization

Severity:	Medium	**CVSS:**	5.4
Affected Asset:	github.com/acme	**Asset Type:**	Code Repository
Exposure:	Internet-facing	**CVE:**	N/A

Description:

The GitHub organization "acme" has 12 members with admin role, including 4 contractors and 2 former employees whose accounts are still active. Admin role grants the ability to delete repositories, modify billing, and add/remove members. No audit log export is enabled.

Impact:

A compromised or malicious admin account could delete all source code, inject backdoors, or exfiltrate proprietary code. No audit trail for forensic analysis.

Recommendation:

1. Review all admin members and reduce to least privilege.
2. Remove access for former employees immediately.
3. Enable GitHub Enterprise audit log export to SIEM.
4. Require MFA for all organization members.
5. Implement a quarterly access review process.

F-010: Unencrypted Backup Tapes in Transit

Severity:	High	**CVSS:**	7.0
Affected Asset:	backup-tape-lot-0917	**Asset Type:**	Backup
Exposure:	Internal	**CVE:**	N/A

Description:

LTO-8 backup tapes containing full database backups are shipped to an offsite storage vendor in unencrypted form. The tapes contain customer PII, financial records, and proprietary source code. The shipping vendor does not provide chain-of-custody tracking.

Impact:

Loss or theft of a single tape constitutes a full data breach. No ability to prove custody or detect interception.

Recommendation:

1. Encrypt all backup tapes using LTO hardware encryption with managed keys.
2. Alternatively, migrate to cloud backup with KMS encryption.
3. Require chain-of-custody documentation from the shipping vendor.
4. Implement a tape inventory and tracking system.
5. Update the data protection policy to mandate encryption at rest for all backups.

End of Report

This report was prepared by Sentrix Security Ltd. for the exclusive use of ACME Corporation. Distribution is restricted to authorized personnel only. The findings and recommendations contained herein are based on the assessment conducted during the stated period and may not reflect changes made after the assessment date.